

Fickle PDFs: exploiting browser rendering discrepancies

Fickle PDFs: exploiting browser rendering discrepancies - Author not stated, PortSwigger Research.

- Published: 2024-07-09
- Original: <<https://portswigger.net/research/fickle-pdfs-exploiting-browser-rendering-discrepancies>>
- Preserved from: <https://portswigger.net/research/fickle-pdfs-exploiting-browser-rendering-discrepancies> (live) on 2026-08-08
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Fickle PDFs: exploiting browser rendering discrepancies | PortSwigger Research

Fickle PDFs: exploiting browser rendering discrepancies

[image: Zakhar Fedotkin]

Zakhar Fedotkin

Researcher

[@zakfedotkin](#)

-

****Published: ****Tuesday, 9 July 2024 at 12:51 UTC

-

****Updated: ****Monday, 15 July 2024 at 09:02 UTC

-

!

Imagine the CEO of a random company receives an email containing a PDF invoice file. In Safari and MacOS Preview, the total price displayed is £399. After approval, the invoice is sent to the

accounting department, which operates on Windows OS. However, when the same PDF file is opened in Google Chrome or Google Drive, the price changes to £999.

In this article, we will show you how to create a hybrid PDF that abuses widget annotations to create render discrepancies, and share the code so you can generate your own.

This research was inspired by Konstantin Weddige's blog post "[Kobold Letters](#)".

Browser PDF rendering discrepancies

Each major browser has its own method for rendering PDF files. Google Chrome uses an integrated PDF viewer called PDFium, while Safari employs its own PDF rendering engine and Firefox uses PDF.js. Thanks to PDF rendering discrepancies, the same PDF file can appear differently across various browsers. For instance, the appearance of interactive form fields varies between browsers. Google Chrome, with its comprehensive support for both interactive form fields and widget annotations, dynamically updates the displayed text from the annotation value to the form field's default value upon user interaction. However, both Firefox and Google Drive preview prioritize the widget annotation, ignoring the default value entirely. In contrast, Safari's PDF rendering engine completely bypasses the widget annotation, displaying only the default value.

To build a proof of concept, we'll use the `org.apache.pdfbox` Java library. Note that the same result can be achieved even with manual file modification. Our interactive form should have at least one input text field and an annotation for it. The plain text value of this field can be any string, such as £399. This value will be shown in PDF readers that do not support forms, such as Safari and MacOS Preview.

Interestingly, the `org.apache.pdfbox.pdmodel.interactive.form.PDTextField#setValue` method also tries to update the visual appearance, unless `PDAcroForm.getNeedAppearances()` is true. However, we won't use the default appearance; instead, we will render our own using widget annotations. These are objects added to a PDF document to provide additional information or interactive elements without altering the original content. A widget annotation represents the appearance of form fields in an interactive PDF form. It will display the text £999 instead. The pseudo code might look like this:

```
PDDocument document = new PDDocument(); PDAcroForm acroForm = new PDAcroForm(document);
PDTextField field = new PDTextField(acroForm); field.setValue("£399"); // Create and set custom appearance
stream PDFormXObject appearanceStream = new PDFormXObject(document); ...
appearanceContents.showText("£999");
```

Note the annotations can contain any text and theoretically, nothing prevents you from overwriting the entire page. The full text can be found at <https://github.com/PortSwigger/research-labs/tree/main/pdf-rendering-discrepancies>

Safari renders the PDF:!

Google Chrome and Drive preview render the different total price:!

Firefox agrees with Google Chrome:!

Interestingly, ChatGPT doesn't support annotations. If you ask it to analyse the invoice, it will return the following:

The PDF file is an invoice for Carlos Montoya with the following details: Invoice Number: 1 Date Issued: 01/01/2001 Date Due: 01/01/3001 Items: Item: L33T Leather Jacket Quantity: 1 Unit Price: £399 Total: £399

Final note

The PDF files rendering process is complex and ambiguous. Be cautious when sending a file to the accounting department for payment or granting a chat assistant access to the mailbox. You can find the Fickle pdf file on [Github](#).

[PDFs](#) [PDF Zakhar](#) [Favourites](#) [Browsers](#)

[Back to all articles](#)

Archived from <https://portswigger.net/research/fickle-pdfs-exploiting-browser-rendering-discrepancies>. Rendered offline from the local Markdown copy.